

账户口令

账户口令

- 账户口令
 - 屏蔽系统帐户
 - 限制使用 su 命令的帐户
 - 设置口令复杂度
 - 设置口令有效期
 - 设置口令的加密算法
 - 登录失败超过三次后锁定
 - 加固 su 命令

屏蔽系统帐户

说明

除了用户帐户外，其他账号称为系统账户。系统账户仅系统内部使用，禁止用于登录系统或其他操作，因此屏蔽系统账户。

实现

将系统帐户的 Shell 修改为/sbin/nologin。

```
usermod -L -s /sbin/nologin $systemaccount
```

说明： \$systemaccount 指系统帐户。

限制使用 su 命令的帐户

说明

su 命令用于在不同帐户之间切换。为了增强系统安全性，有必要对 su 命令的使用权进行控制，只允许 root 和 wheel 分组的帐户使用 su 命令，限制其他帐户使用。

实现

su 命令的使用控制通过修改/etc/pam.d/su 文件实现，配置如下：

```
auth    required    pam_wheel.so use_uid
```

表 1 pam_wheel.so 配置项说明

配置项

说明

use_uid

基于当前帐户的 uid。

设置口令复杂度

说明

用户可以通过修改对应配置文件设置口令的复杂度要求，建议用户根据实际情况设置口令复杂度。

实现

口令复杂度通过/etc/pam.d/password-auth 和/etc/pam.d/system-auth 文件中的 pam_pwquality.so 和 pam_pwhistory.so 模块实现。用户可以通过修改这两个模块中的配置项修改口令复杂度要求。

设置举例

这里给出一个配置口令复杂度的例子，供用户参考。

密码复杂度要求

1. 口令长度至少 8 个字符。
2. 口令必须包含如下至少 3 种字符的组合：
 - 至少一个小写字母
 - 至少一个大写字母
 - 至少一个数字
 - 至少一个特殊字符：`~!@#\$\$%^&*()-_+=\|[]{};:'",/?和空格
3. 口令不能和帐号或者帐号的倒写一样。
4. 不能修改为过去 5 次使用过的旧口令。

配置实现

在/etc/pam.d/password-auth 和/etc/pam.d/system-auth 文件中添加如下配置内容：

```
password requisite pam_pwquality.so minlen=8 minclass=3 enforce_for_root  
try_first_pass local_users_only retry=3 dcredit=0 ucredit=0 lcredit=0 ocredit=0  
password required pam_pwhistory.so use_authtok remember=5 enforce_for_root
```

配置项说明

pam_pwquality.so 和 pam_pwhistory.so 的配置项请分别参见表 2 和表 3。

表 2 pam_pwquality.so 配置项说明

配置项

说明

minlen=8

口令长度至少包含 8 个字符

minclass=3

口令至少包含大写字母、小写字母、数字和特殊字符中的任意 3 种

ucredit=0

口令包含任意个大写字母

lcredit=0

口令包含任意个小写字母

dcredit=0

口令包含任意个数字

ocredit=0

口令包含任意个特殊字符

retry=3

每次修改最多可以尝试 3 次

enforce_for_root

本设置对 root 帐户同样有效

表 3 pam_pwhistory.so 配置项说明

配置项	说明
remember=5	口令不能修改为过去 5 次使用过的旧口令
enforce_for_root	本设置对 root 帐户同样有效

设置口令有效期

说明

出于系统安全性考虑，建议设置口令有效期限，且口令到期前通知用户更改口令。

实现

口令有效期的设置通过修改/etc/login.defs 文件实现，加固项如表 7 所示。表中所有的加固项都在文件/etc/login.defs 中。表中字段直接通过修改配置文件完成。

表 4 login.defs 配置项说明所示

加固项	加固项说明
建议加固	openEuler 默认是否已加固为建议值
PASS_MAX_DAYS	口令最大有效期
90	
否	
PASS_MIN_DAYS	两次修改口令的最小间隔时间
0	

否

PASS_WARN_AGE

口令过期前开始提示天数

7

否

说明： login.defs 是设置用户帐号限制的文件，可配置口令的最大过期天数、最大长度约束等。该文件里的配置对 root 用户无效。如果/etc/shadow 文件里有相同的选项，则以/etc/shadow 配置为准，即/etc/shadow 的配置优先级高于/etc/login.defs。口令过期后用户重新登录时，提示口令过期并强制要求修改，不修改则无法进入系统。

设置口令的加密算法

说明

出于系统安全考虑，口令不允许明文存储在系统中，应该加密保护。在不需要还原口令的场景，必须使用不可逆算法加密。设置口令的加密算法为 sha512，openEuler 默认已设置。通过上述设置可以有效防范口令泄露，保证口令安全。

实现

口令的加密算法设置通过修改/etc/pam.d/password-auth 和/etc/pam.d/system-auth 文件实现，添加如下配置：

```
password sufficient pam_unix.so sha512 shadow nullok try_first_pass use_authtok
```

表 5 pam_unix.so 配置项说明

配置项

说明

sha512

使用 sha512 算法对口令加密。

登录失败超过三次后锁定

说明

为了保障用户系统的安全，建议用户设置口令出错次数的阈值（建议 3 次），以及由于口令尝试被锁定用户的自动解锁时间（建议 300 秒）。

用户锁定期间，任何输入被判定为无效，锁定时间不因用户的再次输入而重新计时；解锁后，用户的错误输入记录被清空。通过上述设置可以有效防范口令被暴力破解，增强系统的安全性。

说明： openEuler 默认口令出错次数的阈值为 3 次，系统被锁定后自动解锁时间为 60 秒。

实现

口令复杂度的设置通过修改/etc/pam.d/password-auth 和/etc/pam.d/system-auth 文件实现，设置口令最大的出错次数 3 次，系统锁定后的解锁时间为 300 秒的配置如下：

```
auth    required    pam_faillock.so preauth audit deny=3 even_deny_root
unlock_time=300
auth    [default=die] pam_faillock.so authfail audit deny=3 even_deny_root
unlock_time=300
auth    sufficient  pam_faillock.so authsucc audit deny=3 even_deny_root
unlock_time=300
```

表 6 pam_faillock.so 配置项说明

配置项

说明

authfail

捕获用户登录失败的事件。

deny=3

用户连续登录失败次数超过 3 次即被锁定。

unlock_time=300

普通用户自动解锁时间为 300 秒（即 5 分钟）。

even_deny_root

同样限制 root 帐户。

加固 su 命令

说明

为了增强系统安全性，防止使用“su”切换用户时将当前用户环境变量带入其他环境，openEuler 默认已做配置。总是在使用 su 切换用户时初始化 PATH。

实现

通过修改/etc/login.defs 实现，配置如下：

```
ALWAYS_SET_PATH=yes
```